

Securitize Whitelist ACL Support Audit Summary

Prepared by Cyfrin

Version 2.0

Lead Auditors

Farouk

Al-qaqa

June 2, 2026

Contents

1 About Cyfrin 2

2 About This Document 2

3 Disclaimer 2

4 Copyright and License 2

5 Audit Overview 3

6 Audit Scope 4

7 Risk Classification 4

8 Protocol Summary 4

9 Attestation 5

1 About Cyfrin

Cyfrin is a Web3 security company dedicated to bringing industry-leading protection and education to our partners and their projects. Our goal is to create a safe, reliable, and transparent environment for everyone in Web3 and DeFi. Learn more about us at cyfrin.io.

2 About This Document

This document is a public summary of the security audit Cyfrin performed for Securitize on Whitelist ACL Support. It records the repositories and commits reviewed, the timeline, auditors, in-scope files, and the number and final status of findings by severity. It closes with Cyfrin's attestation of the review's scope and final remediation status.

It is deliberately abbreviated: the technical detail of individual findings is not reproduced here. The complete audit report, version 2.0 dated June 2, 2026, was delivered to Securitize, who retain it as the full record of the engagement. This summary was issued on October 29, 2026.

3 Disclaimer

The Cyfrin team makes every effort to find as many vulnerabilities in the code as possible in the given time but holds no responsibility for the findings in this document. A security audit by the team does not endorse the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the in-scope code being audited. Unless the scope explicitly notes otherwise, the review is limited to the application layer and does not extend to the correctness of API/SDK/execution environment implementations, compilers, standard and third-party libraries, underlying operating systems and hardware.

4 Copyright and License

© 2026 Cyfrin Inc. All rights reserved. Material from Securitize or third parties remains the property of its owners.

This summary may be shared only in complete and unmodified form, so that any copy can be checked against the hash in its attestation. Short quotations with attribution to Cyfrin are permitted, provided they do not misrepresent this summary's scope or results. Except as permitted by applicable law, no part of this summary may otherwise be copied, modified, adapted, sold or sublicensed, or used to create derivative works, without Cyfrin's prior written permission.

Cyfrin and the Cyfrin logo are trademarks of Cyfrin Inc. and may not be used to suggest that Cyfrin has reviewed or endorses anything outside this summary's scope, or to misrepresent its results.

5 Audit Overview

Over the course of 3 days, the Cyfrin team conducted an audit on the Whitelist ACL Support code provided by Securitize. The findings consist of 1 Low severity issue with the remainder being informational.

Summary

Project Name	Whitelist ACL Support
Repository	bc-solana-whitelist-sc
Commit	fcc2a5df4bc5...
Audit Timeline	May 18th - May 20th, 2026
Methods	Manual Review

Issues Found

Severity	Found	Resolved	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	1	0	1
Informational	4	1	3
Gas Optimizations	0	0	0
Total	5	1	4

6 Audit Scope

See PR1 for the full list of changes. The audit scope was limited to:

```
// new files
programs/spl-token-whitelist/src/instructions/cpi/srfc37/thaw_account.rs
programs/spl-token-whitelist/src/utils/freeze_authority_type.rs

// changed files
programs/dstoken-whitelist/src/instructions/admin/initialize.rs
programs/spl-token-whitelist/src/instructions/admin/change_admin.rs
programs/spl-token-whitelist/src/instructions/admin/initialize.rs
programs/spl-token-whitelist/src/constants.rs
programs/spl-token-whitelist/src/instructions/whitelist.rs

// changed SDK files
packages/spl-token-whitelist-sdk/src/instructions/whitelist.ts
packages/spl-token-whitelist-sdk/src/idl/securitize-solana-spl-whitelist-idl.json
packages/spl-token-whitelist-sdk/src/types/base-types.ts
packages/spl-token-whitelist-sdk/src/types/constants.ts
packages/spl-token-whitelist-sdk/src/types/securitize-solana-spl-whitelist-types.ts
packages/spl-token-whitelist-sdk/src/spl-token-whitelist.ts
```

7 Risk Classification

	Impact: High	**Impact: Medium**	**Impact: Low**
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

8 Protocol Summary

The Securitize SVM Whitelist program is a Solana Anchor-based system that onboards regulated investors into permissioned SPL Token-2022 tokens issued under the Securitize platform. It handles the moment an investor's token account transitions out of the default-frozen state into a transfer-capable state and emits a `Whitelisted` event after the thaw, the on-chain signal that downstream protocol logic and off-chain systems use to recognize the investor as onboarded for that mint.

Onboarding flows through a single `whitelist` instruction that thaws one or more token accounts belonging to the investor in the same call. The mint carries the SPL Token-2022 `DefaultAccountState` extension set to `Frozen`, so newly initialized token accounts for that mint start in the frozen state and cannot hold balance or participate in transfers until the whitelist program thaws them.

This audit covers a delta that adds support for tokens whose Mint and Freeze authorities are held by a separate Token ACL Program PDA rather than by the whitelist program itself. Because SPL Token-2022 binds each mint to a single freeze authority, mints migrated to the ACL authority model cannot be thawed directly by the whitelist program. The updated `whitelist` instruction inspects the mint's on-chain freeze authority and routes the thaw accordingly: legacy mints follow a direct Token-2022 thaw, while ACL-mode mints reach Token-2022 through a CPI into the ACL Program, with an additional sRFC-37 branch that interacts with the upstream `spl-token-access-control` program. The delta also reshapes the `whitelist` instruction's account list: the signer field previously named `freezeAuthority` in the IDL/SDK is renamed to `authority`, a new `freeze_authority` account is added so the program can read the mint's freeze authority from on-chain state when routing, and the SDK is bumped to `v0.1.0` to reflect the breaking interface change.

The program is organized as two sibling Anchor programs: `spl-token-whitelist` for SPL Token-2022 mints and `dstoken-whitelist` for the legacy DSToken flow.

9 Attestation

Cyfrin attests that it performed a security review of the Whitelist ACL Support code provided by Securitize.

The repositories, commits, review period and findings with their final status are in the Summary and Issues Found tables in Section 5, and the in-scope files in Section 6. This attestation is limited to the documented scope, audited commits and mitigations specifically reviewed by Cyfrin.

Cyfrin publishes this document and its SHA-256 hash at https://github.com/Cyfrin/cyfrin-audit-reports. To check a copy on macOS or Linux, run the following in the folder that contains it; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name. Before running it, check that the URL is Cyfrin's repository.

```
U=https://github.com/Cyfrin/cyfrin-audit-reports/raw/main/reports/sha256
N=2026-06-02-cyfrin-securitize-svm-whitelist-acl-support-v2.0.pdf
F=$N
H=$(curl -fsSL $U/$N.sha256 | cut -d' ' -f1)
echo "$H *$F" | shasum -a 256 -c
```

Cyfrin's full audit report with all findings provided to Securitize has the SHA-256 hash and file name below. To check a copy of it, first check this document as above, then run the following in the folder that contains the full report; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name.

```
H=8964fe5a3cdc494299643abb2457fbcc621cadb66c7b8d9c2d25a77ea27a9574
F=2026-06-02-cyfrin-securitize-svm-whitelist-acl-support-v2.0-full.pdf
echo "$H *$F" | shasum -a 256 -c
```

On Linux, `sha256sum -c` can be used in place of `shasum -a 256 -c`. On Windows, run `Get-FileHash <file> -Algorithm SHA256` in PowerShell and compare the result with the hash.